Contents

OWASP Top 10 — Review Checklist **1**
Rules for using this checklist 3
Related 3

OWASP Top 10 — Review Checklist

Walk this on every pull request. Each row names where the risk actually lands in **this** system, not in the abstract.

Source: https://owasp.org/www-project-top-ten/ (2021 edition; re-check the list when OWASP publishes a new one).

#	Risk	Where it bites here	What to check
A01	Broken Access Control	every endpoint and every SignalR group join	both gates present: ownership **and** visibility/licence; object-level check on `GET` by id too; a hidden resource returns `404`, not `403`; hub group join authorised server-side and re-checked on reconnect
A02	Cryptographic Failures	password storage, JWT signing, TLS	BCrypt work factor >= 12; signing key from `.env`, never in source; HTTPS and HSTS; no sensitive data in a JWT payload — it is signed, not secret
A03	Injection	EF Core queries, log messages, YouTube query strings	no string-concatenated SQL; parameterised or `FromSqlInterpolated`; structured log templates, never interpolated user text; user input encoded before it reaches any interpreter
A04	Insecure Design	vote, reorder and control-takeover flows	the invariant is enforced by a database constraint, not by a read-then-write check; the licence and visibility model is evaluated server-side; abuse cases considered, not only happy paths

#	Risk	Where it bites here	What to check
A05	Security Misconfiguration	ASP.NET Core pipeline, containers, Supabase	detailed errors and the interactive OpenAPI UI only in Development; security headers present; CORS an explicit allow-list, never `*` with credentials; container runs non-root; RLS deny-by-default
A06	Vulnerable and Outdated Components	NuGet graph	`dotnet list package --vulnerable --include-transitive` green in CI; no vendored library source; no package version copied from `reference/nArchitecture`
A07	Identification and Authentication Failures	registration, login, reset, social login	rate limits per account **and** per IP; progressive backoff; generic errors (no account enumeration); refresh-token rotation with reuse detection; ID token validated server-side including `aud` and `nonce`
A08	Software and Data Integrity Failures	CI, container images, provider tokens	base images pinned by tag, never `latest`; no secret baked into a layer; a client-supplied profile is never trusted as identity
A09	Security Logging and Monitoring Failures	the mandatory audit log	the audit record carries platform, device, app version; security events logged (failed login, lockout, token reuse, authorisation denial, rate-limit trip); **nothing** on the never-logged list reaches a sink
A10	Server-Side Request Forgery	the YouTube adapter	only fixed provider hosts are called; no user-supplied URL is fetched by the server; timeouts and a circuit breaker on every outbound call

Rules for using this checklist

- A row is not "checked" because the reviewer read it. It is checked because a test, a config artifact or a named code path proves it.
- A finding you cannot fix in this PR goes to [[threat-register]] before the PR merges.
- A01, A07 and A09 map directly onto graded subject requirements (V.6). Treat a finding in those three as blocking.

Related

[[owasp-index]] · [[owasp-api-top10-checklist]] · [[asvs-conformance]] · [[application-security]]